

SECAUDIT 053 - desktop-suite audit-fixes branch: new SQLite content store, COLD SNAP MOSAIC + producer, GYSS wrong-site guard, cross-tool profile read

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Field	Value
Audit ID	2026-09-02-053
Date	2026-09-02
Severity	MEDIUM - no Critical or High. The session's central data-safety mechanism (the GYSS wrong-site-write guard) was adversarially attacked and holds with no bypass. Two MEDIUM items: a latent path-escape / arbitrary-file-type gap at the store_media public API boundary (fixed), and full-EXIF/GPS originals being copied into a shared, backup-eligible store (resolved by removal - the producer now copies no files). Several LOW items (false-green status, reused-image data model, unbounded growth, symlink copy) - one fixed, the rest noted.
Component	Branch claude/desktop-audit-fixes-25f0b2 off dev (0.7.599D), diff git diff dev...HEAD - ~1,300 lines, 16 files. Primary new surface: tools/_shared/snap_library.py (new SQLite content mirror: posts/assets/media), tools/_shared/snap_home.py (media dir). Also tools/coldsnap/ (sumna_post.py MOSAIC + producer, sumna_smacktalk.py, coldsnap.py, profile_manager.py shared-profile read, _version.py), tools/cronometer/heartbeat_client.py, tools/hub/main.py, tools/gyss/src/scripts/main.js.
Status	CLOSED 2026-09-18 . A, B, C closed Sep 2. F (silent producer errors) and the suite-wide Bearer-on-redirect hardening fixed in 0.7.724D. E is moot (producer copies no files). D FIXED 2026-09-05 (651D): post_assets join table - the same image in two posts stays attached to both; self-healing migration folds legacy rows in. Regression: tools/_shared/tests/test_snap_library_reuse.py. Branch merged to dev as 0.7.631D. See §10. Original working status: Findings A (store_media containment) and C (GYSS false-green status) CLOSED in commit 44ff1bd7. Finding B (GPS originals in shared store) RESOLVED BY REMOVAL post-audit (producer records ids, copies no files). Findings D-F (data model, unbounded growth, symlink copy, silent producer errors) NOTED - owner/deferred. Branch not merged ; real sign-off is Sean's live post rendering the MOSAIC.
Reporter	Sean (commissioned a full secaudit on all branch changes, "we've opened pathways... we will for sure find issues") + Claude (author adversarial self-pass on the remainder) + two independent adversarial sub-reviewers - one on the SQLite content store + COLD SNAP producer, one on the GYSS guard + the cross-tool profile read. Two-reviewer discipline per 050.
Related	039 (GYSS desktop client attack surface - same webview client; this session added the wrong-site write guard to it), 044 (hub read-side shared profiles/prompts - COLD SNAP now joins that same shared snap_profiles read), 049 (post-model consumer inventory - the new content store mirrors the post model), 050 (false-done / don't-drop-to-single-reviewer discipline - the guardrail that caught Finding C). COLD SNAP at audit: 0.7.8 ; core/dev at 0.7.599D .
Disclosure	No exploitation known. These are single-operator desktop tools. Every finding requires either local disk access to C:\snapsmack\ (the shared library, vault, profiles) or the operator connecting a tool to a hostile server. Nothing here is remotely reachable by an unauthenticated attacker. The one privacy item (B) is a local data-at-rest concern, not remote exfil.

1. Summary

This branch repaired the desktop-tools-interface-audit-2026-09-01 findings and, more substantially, built the shared SQLite **content store** COLD SNAP needs to compose long-form posts and record what it posts (the shared-library-post-cache-producer spec). That is genuinely new attack surface - a local database with file writes, new outbound HTTP calls, and cross-tool access to stored API keys - which is why Sean commissioned a full pass before the code goes anywhere near a live site.

The result is clean. **No Critical or High**. The one item that carried real data-safety weight - the GYSS guard that must prevent a resumed sort session from pushing its edits to the *wrong* blog - was specifically attacked (scheme, port, user@host, punycode, trailing slash, path) and **has no bypass**; both write paths are guarded. Server-side query hygiene, path containment, transaction integrity, and secret handling all held.

Two MEDIUM findings emerged. One (A) is a latent path-escape at a shared public API that no shipped caller can reach but a future one could - fixed at the boundary. The other (B) is the important one, and Sean caught it in parallel with the audit: the COLD SNAP producer was silently copying the photographer's **original** photos (often RAW, never uploaded; full EXIF including GPS) into a shared, backup-eligible folder on every post. That was an undisclosed shadow-backup and a drift of the store's own "cache, not archive" design. It was removed at the root: the producer now records only what was posted, and copies no photo files.

Six findings; two closed, one resolved by removal, three noted.

2. Method - what was examined and how

- **Target:** the complete branch diff `git diff dev...HEAD` (16 files, ~1,300 lines),

read against the **full current files** for context, not the hunks in isolation. Live server code (`core/smackpress-api.php`, `core/parser.php`) was cross-checked directly where the desktop code depends on a server contract, so the review is grounded in code, not memory.

- **Two independent adversarial reviewers**, each given one risk cluster and told to

try to break it (per 050, not a single self-audit):

1. **Content store + producer** - `snap_library.py`, `snap_home.py` /

`snap_paths.contained_local_path`, and `sumna_post._record_to_library / store_media`. Hunted: SQL injection across every query; path traversal / arbitrary write in `store_media` (`ext/orig_name/site -> media dir`); sha256 dedupe collision/clobber; EXIF/GPS/PII exposure; unbounded growth; symlink following; transaction corruption; secret leakage in errors.

2. **GYSS guard + cross-tool profiles** - the new `normalizeSiteURL /`

`apiTargetsSite / restoreSessionProfile`, the PUSH and keep-mine force-push guards, the drag once-guard, and `coldsnap/profile_manager.py` now reading the shared `snap_profiles` store (plaintext keys). Hunted: guard bypass via URL canonicalisation tricks; whether every write path is guarded; tampered-session redirection; secret exposure via the profile mapping; regression from the listener change.

- **Author self-pass** on the remainder: the `[mosaic]` regex substitution into post

bodies, the CRONOMETER heartbeat re-fetch, the HQ credential-clear logic, and the `site_key / contained_local_path` containment the store relies on.

- **Verification:** each fix was covered by a regression test and the affected desktop

test suites re-run green; the COLD SNAP exe was rebuilt off this branch and launch-verified after the fixes.

3. Finding A - store_media builds the media filename without containment; ext can escape or plant an arbitrary type (MEDIUM) - CLOSED (44ff1bd7)

tools/_shared/snap_library.py, store_media(). Every other path segment in the suite is routed through contained_local_path (the codebase's jail-every-path doctrine); the final media filename <asset_id><ext> was the one exception. asset_id is a safe sha256 hex string, so filename safety rested entirely on ext.

- **Traversal (via an explicit ext kwarg):** store_media(site, data, ext="../../../evil.exe")

-> os.path.join(media_dir, sha + "../../../evil.exe") normalises above the media dir - an arbitrary write. Also reachable on Windows via an NTFS alternate-data-stream ext=".jpg:evil".

- **Arbitrary extension (via orig_name on the bytes branch):** orig_name="evil.php"

/ "evil.lnk" writes <sha>.php / <sha>.lnk into the store; _EXT_MIME.get() returned "" for unknown types but the file was still written.

Not reachable via the shipped COLD SNAP producer - it passed only a filesystem-path source, so ext derived from os.path.splitext(path)[1], which never contains a separator. But store_media is a **cross-tool public function**; the next producer (SMACKPRESS, SYBU, GYSS, any byte-source caller) hits the bytes branch and/or passes ext, and would inherit the hole silently. This is defence at the API boundary, not at today's one safe caller.

Fix applied. ext is restricted to the _EXT_MIME image allowlist (unknown -> dropped), and the final filename is built through contained_local_path, restoring consistency with the suite's containment doctrine. Regression test (tests/test_snap_library_posts.py::test_store_media_neutralizes_hostile_ext) asserts a traversal ext stays inside the media dir, a .php orig_name is dropped, and a legitimate image ext is kept.

4. Finding B - full-EXIF/GPS originals copied into a shared, backup-eligible store (MEDIUM, privacy) - RESOLVED BY REMOVAL

tools/coldsnap/sumna_post.py, _record_to_library() -> snap_library.store_media(). On every successful post the producer copied each image's **original** bytes verbatim into shared_library/<site>/media. SNAP SLAPPER deliberately never strips EXIF, so those originals carry capture **GPS**. The store is shared across tools and sits under C:\snapsmack beside the auth vault, profiles, and the SUYB / Drive-mirror backup surface. Net effect: a growing pile of geotagged originals - many of them RAW files the server never received - accumulating in one shared location a cloud mirror would carry offsite.

Two problems in one: a **privacy** leak (GPS reaching a backup-eligible location silently) and an **architecture drift** - the store is specified as a *cache of authoritative server state*, and a cache that hoards RAW originals the server never held is a shadow backup, not a cache. The root cause was a process error: the producer spec left "full-res original vs web-size upload" as an explicit open question, and it was defaulted to "original" without the owner - a call with a data-at-rest and privacy consequence that should have been Sean's, not a silent default.

Resolution (Sean's decision, applied): the producer now records only **what was posted** - the post text and the server's snap_images ids for the images used (asset_id "img:<id>") - and **copies zero photo files**. Originals stay on the photographer's disk untouched; the web-size upload and thumbs already exist from the post. The GPS-offsite concern is closed by *non-collection* (a file never copied can't leak - the same privacy stance used fleet-wide), not by scrubbing. store_media remains only as the now-hardened (Finding A) utility for a **future, explicit, opt-in** "keep originals" feature - never automatic. Governing principle recorded: **the user is responsible for archiving their own originals and finals; tools never silently archive files.**

5. Finding C - GYSS restoreSessionProfile could report 'ok' for a same-named different site (LOW, truth-integrity) - CLOSED (44ff1bd7)

tools/gyss/src/scripts/main.js. On resume, the profile match falls back from site_url to **profile name**; a name can be shared by two different sites, so the name-fallback could load a *different* site's profile and still return 'ok' - the "connected to this session's site" status - with no warning banner.

Scored LOW because it is **not** a data-safety hole: the PUSH handler and the keep-mine force-push each independently re-run `apiTargetsSite(session.site_url)`, which compares `state.api.baseUrl` to the session's site and blocks the write; the PUSH button stays disabled with an explanatory title. But a status that says "ok" when the thing did not happen is a **false-green**, the exact class Sean's "done = verified" standard exists to kill - the same species as the CRONOMETER stale-verdict fixed elsewhere on this branch. It was caught precisely because the review used two independent reviewers rather than a single self-audit.

Fix applied. After the name-fallback loads, `restoreSessionProfile` re-checks the loaded profile's site and returns 'not-found' (showing the warning) on mismatch, instead of a misleading 'ok'. A comment notes session files are trusted local input.

6. Findings D-F - noted, no fix this pass

- **D (LOW) - reused-image data model.** `assets.asset_id` is the primary key and

`assets.post_id` is single-valued, so the same image (identical bytes) posted in two posts has its `post_id` overwritten to the newer post; `assets_for(old_post)` drops it. Correctness limitation, not a breach. If a photographer reuses a shot across posts and both should keep it, move to a `post_assets(post_id, asset_id)` join table.

- **E (LOW) - unbounded growth / symlink copy / TOCTOU.** No media size cap;

`shutil.copyfile` follows symlinks (a source symlink to a sensitive file would copy its content in - sources are user-selected files, so LOW, and moot now that the producer copies nothing); hash-then-copy race on a single-user desktop is LOW.

- **F (LOW) - silent producer errors.** `_record_to_library` is wrapped in a blanket

`try/except: pass` (correct - a library hiccup must never fail a live post), but a persistently broken mirror is invisible. Recommend a debug-level log on the outer except so a silently-empty library is diagnosable.

- **Pre-existing, not introduced here:** the CRONOMETER heartbeat re-fetch and every

suite API client follow HTTP redirects with the Bearer key attached. Worth a future hardening pass (strip auth on cross-host redirect), but this branch did not create it.

7. What held up

- **SQL injection - none.** Every value in `record_post`, `posts()`, `assets_for()`,

`has_source_ref()`, `post()`, `meta()`, `sync_from_sybu_data()` is bound with ? placeholders. The only f-string-built SQL (`_descs`) uses hard-coded table literals ("categories"/"albums") from internal callers, never input. `posts()` builds its WHERE from constant column fragments with parameterised values. `int(post_id)` coercion blocks key injection.

- **Site-path containment solid.** `site_key()` reduces any URL to a lowercased

`hostname([a-z0-9.-] only; strips path, port, user:pass@)`, then `contained_local_path` rejects `...`, absolute paths, and NUL via a `commonpath` jail. A crafted host cannot escape `shared_library/`.

- **No wrong-site-write guard bypass.** Every structural URL difference

(`scheme/port/user@host/punycode/host/path/fragment`) makes the two normalised strings differ, which *blocks* the push. The constructor stripping only one trailing slash is safely absorbed because `normalizeSiteUrl` strips all trailing slashes on both operands. Both session-write paths (PUSH `batchUpdate`, keep-mine force `batchUpdate`) are guarded; the other server-mutating calls (`enrichOne`, `gramReorder`, `gramCarousel`) operate on the live-connected site with data from that same site and correctly need no session guard.

- **sha256 dedupe** collision/preimage infeasible; `if not os.path.isfile` idempotency

correct; different bytes -> different ids, no cross-asset clobber.

- **Transaction integrity.** record_post and sync_from_sybu_data use with conn: -

a mid-loop failure rolls the whole post+assets write back atomically.

- **No secret leakage.** COLD SNAP surfacing shared API keys is by design; no key is

logged or placed in an error string; _shared_to_coldsnap's extras.setdefault loop cannot overwrite the real url/api_key/smackpress_key (all set first).

- [mosaic] **substitution** uses a replacement *function* (lambda), so a

server-retained shortcode containing regex backreferences (\1, \g<0>) cannot be interpreted; the body is sanitised server-side.

- **Drag once-guard** correct - bindSortTab runs once at DOMContentLoaded; the

delegated #sort-grid listeners survive innerHTML re-renders (this fixed the prior per-render listener stacking).

8. Recommendations

1. **Ship the branch through a live post before calling any of it done.** Everything is

built and logic-verified with fakes; "done" is Sean's live essay rendering its MOSAIC on the site. If it fails, the map is: the marker->id transform, the record write, or the smackpress-key handshake - one failed post tells which.

2. **Owner decision on D (reused-image membership):** leave single-post, or add a

post_assets join table if shots are reused across posts and both should retain them.

3. **Carry the "reads the wrong store" pattern to the Codex _shared reconcile.** COLD

SNAP read a *local profiles/* folder instead of the shared snap_profiles store (fixed here) - the same "wrong half / wrong store" shape as the vocabulary-only catalog that opened this session. Sweep the other tools for the same habit during the reconcile.

4. **Future hardening (not this branch):** strip the Bearer header on cross-host HTTP

redirects across the suite's API clients; add a debug log on the producer's silent except (F).

5. **Keep store_media opt-in only.** It is hardened (A) but must never be wired to

auto-copy user files again; any "keep originals/finals" backup is an explicit, labelled, user-toggled feature.

9. Closure checklist

- [x] A - store_media ext restricted to image allowlist + filename routed through contained_local_path; regression test added
- [x] B - producer records post + server image ids, copies zero photo files; GPS-offsite closed by non-collection; principle recorded
- [x] C - GYSS resume returns 'not-found' on a name-collision mismatch instead of a false 'ok'
- [x] Two independent adversarial reviewers + author pass (050 discipline)
- [x] Contract cross-checked against live core/smackpress-api.php / core/parser.php (Gallery snap_images target confirmed)
- [x] Affected desktop test suites re-run green; COLD SNAP exe rebuilt off the branch and launch-verified
- [x] E - moot: the producer copies no files (B), so symlink-follow, size cap and TOCTOU on the copy path have nothing to act on
- [x] F - producer's silent except: pass now logs a warning with traceback (coldsnap.library logger) - 0.7.724D

- [x] Suite-wide: refuse redirects on credentialed urllib requests (7 files) - 0.7.724D; requests already strips Authorization cross-host. Test: `tests/test_urllib_no_redirect_with_credentials.py`
- [x] Branch merged to dev - 0.7.631D (2026-09-05)
- [x] D - reused-image join table - FIXED 2026-09-05 in 651D (`snap_library.py: post_assets(post_id, asset_id, ord)`); `assets_for()` reads the join table; legacy `assets.post_id` folded in and consumed on every open). Sean 2026-09-18: the local mirror MUST match the online DB - a missing post is a bug, not a preference. Verified today: same asset recorded for posts 1 and 2 -> both return it. Regression `tools/_shared/tests/test_snap_library_reuse.py`
- [] Live post sign-off - Sean composes an essay + MOSAIC and confirms it renders (feature acceptance, not an audit gate)

10. Closure - Claude, 2026-09-18

Re-read against dev at v0.7.723D. The security content of this audit was closed on Sep 2 (A, C) and by design change (B). What remained was one observability fix (F), one hardening note (redirects), and two non-security items. F and the redirect hardening shipped in 0.7.724D. E has nothing left to act on. D had already been fixed on Sep 5 (651D) - this report was stale on that too, and my first closure pass repeated the stale text. Sean's rule, recorded: the local mirror must match the online DB; a post missing from it is breakage. Audit CLOSED; only the live-post acceptance check remains, and that is feature acceptance.